

Cloud Architecture Design & Security Patterns

A detailed walkthrough of the three-tier VPC pattern — what each piece is for, how to build it by hand, and how to layer two recognized security patterns on top — with an illustrated console example at every step.

Rubric text: the project must demonstrate secure cloud architecture design using industry patterns. Students must create a three-tier architecture diagram showing VPC design with public/private subnets, security groups, and NACLs using diagramming tools. Implementation must include hands-on VPC configuration in AWS, Azure, or GCP with subnet segmentation and security group rules, plus implementation of two security design patterns (bastion host, hub-and-spoke, or zero trust) with documented configuration steps and screenshots.

How to read this guide. Every console view in the pages that follow is a built illustration, styled to look like a cloud console, not a real screenshot — there was no live AWS/Azure/GCP account to capture from here. Treat each one as a worked example of what your own evidence should look like: recreate the same action in your own account and capture *that* as your real rubric screenshot.

01	Core concepts	
02	The architecture diagram	
03	Building the VPC by hand	
04	Security groups & NACLs in practice	
05	Pattern 1 — Bastion host	
06	Pattern 2 — Zero trust segmentation	
07	Terms across AWS, Azure, and GCP	
08	Glossary	
09	Rubric self-check	

Worked example used throughout: a fictional three-tier web app, Meridian Clinic Portal — a public booking site (Web), its API (App), and its patient-records database (Data). The names and IDs in every mockup below belong to this example only.

VPC, tiers, and the two firewalls

A **VPC** (virtual private cloud) is your own private slice of network inside a cloud provider — you choose its address range, and by default nothing outside it can reach in. Everything else in this guide is about how you subdivide that one network and decide what can talk to what.

Why three tiers. Splitting an application into Web, App, and Data tiers means a problem in one tier doesn't automatically hand over the next. The tier facing the internet is the one that takes the risk first, so it should also be the one with the least to lose if it's ever breached — it holds no data of its own, only the App tier does, and the App tier in turn is the only thing allowed to reach the Data tier.

What actually makes a subnet "public." Nothing about a subnet is inherently public or private — it's public only because its route table sends outbound traffic to an internet gateway. A private subnet simply never gets that route. If it needs to reach the internet at all (to download a security patch, for example), it goes out through a NAT gateway instead, which lets traffic leave but never lets a new connection in.

Why this distinction matters for the rubric: a grader checking your diagram is checking exactly this — that only the Web tier's subnets route to an internet gateway, and that App and Data sit behind a NAT gateway with no direct inbound path at all.

The two firewalls, side by side

SECURITY GROUP	NETWORK ACL (NACL)
Attaches to an instance (or a group of them)	Attaches to a subnet — applies to everything inside it
Stateful — allow the request in, and the reply is automatically allowed back out	Stateless — the reply needs its own explicit rule, usually on a high ("ephemeral") port range
Allow rules only; nothing to deny explicitly, whatever isn't allowed is dropped	Numbered allow <i>and</i> deny rules, evaluated in order
Fine-grained — "only this other security group may reach me"	Coarse — a deny-by-default backstop at the subnet's edge

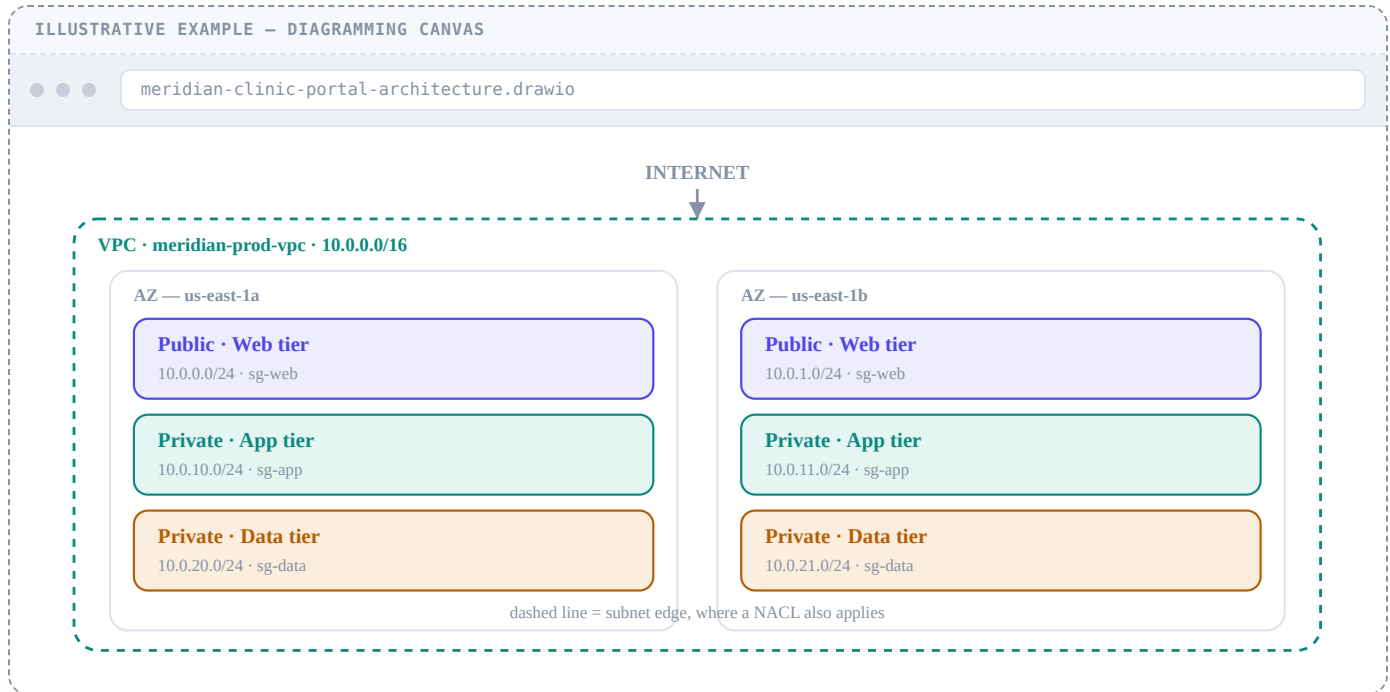
Think of the security group as the lock on each apartment door, and the NACL as the guard at the building's front entrance — both are checking, but at different points, and neither one is a substitute for the other.

Glossary you'll need for this section

TERM	WHAT IT IS
VPC	Your isolated virtual network inside the cloud, defined by a CIDR block such as <code>10.0.0.0/16</code>
Subnet	A slice of the VPC's address range, pinned to one Availability Zone
Availability Zone (AZ)	A physically separate data center within the same region — using two protects against one AZ failing
Internet gateway	The door that makes a subnet's route table — and therefore the subnet — public
NAT gateway	Lets a private subnet reach out to the internet without allowing anything to reach in

Drawing it before you build it

The rubric asks for this diagram first, before any console work, and that order is deliberate — it's much cheaper to redesign six boxes on a canvas than six real subnets. Use a diagramming tool built for this: draw.io / diagrams.net and Lucidchart both ship with ready-made AWS/Azure/GCP icon sets, which also makes the diagram instantly readable to a grader who works across clouds.



What the diagram must show

- All six subnets — three tiers × two Availability Zones — each clearly labeled public or private
- The security group attached to each tier, by name
- Where the NACL sits (the subnet boundary itself, not inside it)
- The internet gateway, and the NAT gateway that serves the private tiers

Common mistakes graders flag: drawing only one Availability Zone (a single point of failure the rubric is specifically checking for), putting the App or Data tier in a public subnet, or drawing one shared "firewall" box instead of a security group per tier.

Capture: export your version of this diagram as a PNG or PDF — this is the first graded deliverable.

From diagram to running network

This section turns the diagram into a real VPC, one console action at a time. The examples below are shown in AWS-style console screens; the same four actions exist under different names in Azure and GCP — see the terms table in Section 07.

3.1 · Create the VPC

ILLUSTRATIVE EXAMPLE — CREATE VPC

console > VPC > Your VPCs > Create VPC

NAME TAG	IPV4 CIDR BLOCK	TENANCY
meridian-prod-vpc	10.0.0.0/16	Default

Create VPC

3.2 · Attach the two gateways

ILLUSTRATIVE EXAMPLE — GATEWAYS

console > VPC > meridian-prod-vpc > Gateways

RESOURCE	ID	ATTACHED TO	PURPOSE
Internet gateway	igw-0a1b2c3	meridian-prod-vpc	Makes the two Web subnets public
NAT gateway	nat-0d4e5f6	Web subnet, AZ-a	Outbound-only path for App & Data tiers

Placing a NAT gateway inside a public subnet, rather than a private one, is what lets it reach the internet gateway on the private tiers' behalf.

3.3 · Carve out the six subnets

ILLUSTRATIVE EXAMPLE — SUBNETS

console > VPC > Subnets

NAME	AZ	CIDR	TYPE	AUTO-ASSIGN PUBLIC IP
web-a	us-east-1a	10.0.0.0/24	Public	Yes
web-b	us-east-1b	10.0.1.0/24	Public	Yes
app-a	us-east-1a	10.0.10.0/24	Private	No
app-b	us-east-1b	10.0.11.0/24	Private	No
data-a	us-east-1a	10.0.20.0/24	Private	No
data-b	us-east-1b	10.0.21.0/24	Private	No

3.4 · Point each subnet at the right route table

ILLUSTRATIVE EXAMPLE – ROUTE TABLES

console > VPC > Route tables

ROUTE TABLE	DESTINATION	TARGET	ASSOCIATED SUBNETS
rtb-public	0.0.0.0/0	igw-0a1b2c3	web-a, web-b
rtb-private	0.0.0.0/0	nat-0d4e5f6	app-a, app-b, data-a, data-b

Capture: screenshots of the subnet list and the route table associations — this is the second graded deliverable, alongside the security group rules in Section 04.

Writing the actual rules

Every rule below names another security group as its source, instead of an IP range, wherever the traffic is coming from inside the VPC. That single habit is most of what "least privilege" means in practice: a rule that says "only `sg-web` may reach me" stays true even if the Web tier's IP addresses change, and it's unambiguous to a grader reading it.

ILLUSTRATIVE EXAMPLE – SECURITY GROUP INBOUND RULES

console > VPC > Security groups > Inbound rules

SECURITY GROUP	PORT	PROTOCOL	SOURCE	REASON
sg-web	443	TCP	0.0.0.0/0	Public HTTPS traffic
sg-app	8080	TCP	sg-web	Only the Web tier calls the API
sg-data	5432	TCP	sg-app	Only the App tier queries the database

Why sg-data has no rule at all for sg-web: the Data tier should never accept a connection from the Web tier directly — if it did, a bug or breach in the Web tier could reach patient records without ever passing through the App tier's own checks.

NACLs: the subnet-level backstop

Because a NACL is stateless, it needs one rule for the request and a separate rule for the reply. Forgetting the reply rule is the single most common reason a working security-group setup still fails to connect.

ILLUSTRATIVE EXAMPLE – NACL RULES ON THE APP SUBNET

console > VPC > Network ACLs > nACL-app

RULE #	TYPE	PORT RANGE	SOURCE	ACTION
100	Inbound	8080	10.0.0.0/24, 10.0.1.0/24	Allow
110	Inbound	1024–65535	0.0.0.0/0	Allow (return traffic)
*	Inbound	All	0.0.0.0/0	Deny

Capture: the inbound rules screen for each security group, plus one NACL — enough to show the grader both layers are configured, not just one.

One locked door for administrators

A bastion host is a single, deliberately narrow entry point for the people who administer the system — instead of every instance in the App and Data tiers accepting SSH or RDP from an admin's laptop, only the bastion does, and everything else only accepts a connection that already came through it.

- Launch a small instance in a public subnet, used for nothing except administrative access
- Its security group allows SSH (22) or RDP (3389) only from your specific admin IP address, never `0.0.0.0/0`
- Remove any direct admin-port rule from `sg-app` and `sg-data` — they should accept SSH/RDP only with the bastion's security group as the source
- Turn on session logging so every administrative connection is recorded

ILLUSTRATIVE EXAMPLE – BASTION SECURITY GROUP

console > VPC > Security groups > sg-bastion

PORT	PROTOCOL	SOURCE	NOTE
22	TCP	203.0.113.4/32	Admin's home/office IP only
SG-APP INBOUND (ADMIN ACCESS ROW ONLY)			
22 · TCP		Source: sg-bastion — not a CIDR range	

A stronger, keyless variant: AWS Systems Manager Session Manager, Azure Bastion, and GCP's Identity-Aware Proxy all let you reach a private instance with no inbound port open at all — access is brokered through the cloud provider's own IAM instead of a listening SSH port. This still satisfies the bastion pattern for the rubric, and is worth documenting as your implementation if your cloud track offers it.

Capture: the bastion's own security group rules, the admin-only rule on the tiers behind it, and a short written note on the steps you took — this is the first of the two graded security-pattern deliverables.

Never trust a connection just because of where it's from

Zero trust starts from one assumption: being inside the VPC doesn't make a request trustworthy. Every hop, even one subnet over, is checked as if it were crossing the open internet. In practice, for this rubric row, that means auditing what you already built in Sections 03–04 and tightening anything that trusts a network location instead of a verified identity.

Before / after audit

ILLUSTRATIVE EXAMPLE – TIGHTENING AN OVER-BROAD RULE

console > VPC > Security groups > sg-app (audit)

BEFORE

8080 · TCP

10.0.0.0/16

Trusts the whole VPC's address range — any compromised instance anywhere could reach the API.

AFTER

8080 · TCP

sg-web

Trusts one named, identity-backed source — the actual Web tier, nothing else.

- Re-check every security group for a rule that names a CIDR range where a security group name would do instead
- Turn on VPC flow logs so every allowed and rejected connection is recorded, not just the ones you expect
- Confirm the Data tier's security group has no rule at all for the Web tier — not even a narrow one
- Repeat the audit on a schedule; zero trust is a posture you maintain, not a one-time setting

ILLUSTRATIVE EXAMPLE – FLOW LOG SAMPLE

console > VPC > Flow logs > meridian-prod-vpc

SOURCE	DESTINATION	PORT	ACTION
10.0.0.14	10.0.10.9	8080	Accept
10.0.20.7	10.0.0.14	22	Reject

The rejected row is the Data tier trying to reach the Web tier over SSH — exactly the lateral movement zero trust is meant to catch.

If your track prefers hub-and-spoke instead: route all inter-VPC or inter-tier traffic through one central hub (a Transit Gateway in AWS, a Virtual WAN hub in Azure, a Shared VPC in GCP) so every path can be inspected in one place. The evidence looks different — a hub/spoke route table and an inspection log, rather than a before/after rule diff — but it satisfies the same rubric row.

Capture: the before/after rule screenshots and the flow-log configuration — the second of the two graded security-pattern deliverables.

Same idea, different console

The rubric accepts any of the three clouds. Everything built in Sections 03–06 above used AWS-style names; here is where each concept lives if your track is Azure or GCP instead.

CONCEPT	AWS	AZURE	GCP
Virtual network	VPC	Virtual Network (VNet)	VPC network
Network slice	Subnet	Subnet	Subnet
Instance-level firewall	Security Group	NSG (attached to the NIC)	Firewall rule (by network tag)
Subnet-level firewall	Network ACL	NSG (attached to the subnet)	Firewall rule (by subnet)
Public door	Internet Gateway	Public IP + Load Balancer	Default internet gateway
Outbound-only door	NAT Gateway	Azure NAT Gateway	Cloud NAT
Bastion	EC2 in a public subnet	Azure Bastion	IAP-tunneled VM
Hub-and-spoke hub	Transit Gateway	Virtual WAN hub	Shared VPC
Connection logging	VPC Flow Logs	NSG Flow Logs	VPC Flow Logs

Whichever cloud you use, keep the naming consistent between your diagram, your console screenshots, and your written configuration steps — a grader matching evidence to the diagram is the whole point of this rubric row.

Every term used in this guide

Availability Zone (AZ)

A physically separate data center within one cloud region.

Bastion host

A single hardened instance that is the only allowed path for administrative access.

CIDR block

A written address range, e.g. 10.0.0.0/16, sized by how many addresses it covers.

Flow logs

A record of every connection attempt through a VPC, accepted or rejected.

Hub-and-spoke

A pattern that routes all traffic between networks through one central, inspectable hub.

Internet gateway (IGW)

The component that gives a VPC, and any subnet routed to it, a path to the public internet.

NACL

Network Access Control List — a stateless, subnet-level firewall.

NAT gateway

Lets a private subnet make outbound connections without accepting inbound ones.

Private subnet

A subnet whose route table has no path to an internet gateway.

Public subnet

A subnet whose route table sends traffic to an internet gateway.

Route table

The rules that decide where a subnet's traffic goes next.

Security group

A stateful, instance-level firewall; allow rules only.

Stateful / stateless

Stateful remembers a connection and allows its reply automatically; stateless checks every packet on its own.

Three-tier architecture

Splitting an app into Web, App, and Data layers so a breach in one doesn't hand over the next.

VPC

Virtual Private Cloud — your own isolated network inside the cloud provider.

Zero trust

A posture that verifies every request by identity, never by network location alone.

Before you submit

Three deliverables, matched back to where each one is covered in this guide.

-
- ☐ **Three-tier architecture diagram**
Six subnets across two AZs, each labeled public or private, with security groups and NACLs marked — made in a diagramming tool. Covered in Sections 01–02.
 - ☐ **Working VPC with subnet segmentation and security group rules**
The VPC, its six subnets, route tables, and security group / NACL rules actually built in AWS, Azure, or GCP, matching the diagram. Covered in Sections 03–04.
 - ☐ **Two implemented security design patterns**
Bastion host, hub-and-spoke, or zero trust — any two, each with documented configuration steps and screenshots. Covered in Sections 05–06.
-

Package all three into one document or slide deck, in this order, so a grader can check each rubric row without hunting for the matching evidence.